ENSEMBLE METHODS

AI GOVERNANCE FRAMEWORKS

Research & Reference Guide

A vendor-neutral guide to recognized standards, enterprise frameworks, practical controls, and implementation resources for organizations expanding data governance into AI governance.

Prepared by Ensemble Methods | Advisory · Training · Hands-on Implementation

Publication date 6 November 2026

Audience Business leaders, data and AI governance teams, risk, security, compliance and technology stakeholders

Different Inputs. One Outcome.

Practical, informed governance for responsible AI adoption.

Executive perspective

AI governance should not be introduced as a replacement for data governance, or as a feature supplied by one technology vendor. It should extend existing enterprise governance with additional accountability for AI systems, model and agent behavior, human oversight, validation, security and continuous monitoring.

Recommended reference stack

NIST AI RMF for risk structure | **ISO/IEC 42001** for the management system | **Databricks DAGF** for practical enterprise considerations | **CSA AI Controls Matrix** for detailed controls. Use Microsoft, AWS, IBM, OECD, OWASP and relevant laws as complementary references.

How to interpret the resource landscape

Category	What it contributes	Primary references
Independent frameworks	Core concepts, AI risks, trusted governance vocabulary	NIST AI RMF; OECD AI Principles
Formal standards	Organizational management requirements and assessment methods	ISO/IEC 42001; 23894; 42005
Vendor frameworks	Practical design patterns, delivery practices and platform examples	Databricks; Microsoft; AWS; IBM
Control and security guides	Detailed objectives, technical risks, evidence and assurance	CSA AICM; OWASP
Legal requirements	Binding duties in jurisdictions and use cases where applicable	EU AI Act; applicable sectoral/local rules

Reading guide

This publication is a **curated research guide**, not a certification guide or legal opinion. Sources are grouped by the decision they help inform, with official links to primary material. Selection guidance and proposed implementation stages are Ensemble Methods recommendations, not normative requirements of the referenced organizations.

Suggested reading sequence

- **01 Establish principles** — OECD AI Principles and NIST AI RMF
- **02 Define a management system** — ISO/IEC 42001 with ISO/IEC 23894 and 42005
- **03 Translate into enterprise practice** — Databricks DAGF; Microsoft; AWS; IBM
- **04 Design controls and assurance** — CSA AI Controls Matrix and OWASP GenAI resources
- **05 Address regulatory obligations** — EU AI Act and the client's applicable jurisdiction and industry rules

01 / Independent standards and principles

Use these references to define the foundation before choosing a cloud platform, model provider or governance technology. A voluntary framework, a published standard and a legal requirement carry different obligations.

NIST AI Risk Management Framework (AI RMF 1.0)

VOLUNTARY FRAMEWORK

Best used for: Core enterprise AI risk governance, assessment and monitoring.

Four functions: **Govern, Map, Measure, Manage**. Start with the core framework, then use the NIST AI RMF Playbook for suggested actions and the Generative AI Profile for GenAI-specific risks. NIST notes that AI RMF 1.0 is being revised.

Official reference / resource

ISO/IEC 42001:2023 — AI Management System

INTERNATIONAL STANDARD

Best used for: Establishing, maintaining and auditing an organization-wide AI management system.

Provides formal management-system requirements across policy, governance, risk, organizational responsibilities, operations and continual improvement. The full standard is generally paid; the ISO overview is public.

Official reference / resource

ISO/IEC 23894:2023 — AI Risk Management

INTERNATIONAL GUIDANCE

Best used for: AI-specific risk management processes and integration with existing enterprise risk practices.

Complementary guidance rather than a substitute for the AI management system or enterprise risk framework.

Official reference / resource

ISO/IEC 42005:2025 — AI System Impact Assessment

INTERNATIONAL GUIDANCE

Best used for: Structured consideration of effects on individuals, groups and society.

Useful for consequential AI systems and documented impact assessments across the lifecycle. The full standard is generally paid.

Official reference / resource

OECD AI Principles

INTERGOVERNMENTAL PRINCIPLES

Best used for: Drafting trustworthy and responsible AI principles for executives and policy owners.

Five values-based principles, adopted in 2019 and updated in 2024. Strong for setting organizational commitments; not a detailed technical control checklist.

Official reference / resource

02 / Enterprise and vendor frameworks

Vendor guidance is useful for operational patterns and exemplars. It should inform—but not determine—the organization's platform-neutral policy, control objectives or risk appetite.

Databricks AI Governance Framework (DAGF)

ENTERPRISE FRAMEWORK

Best used for: A practical AI governance blueprint for organizational design and gap assessments.

Five pillars, 43 key considerations: **AI Organization; Legal and Regulatory Compliance; Ethics, Transparency and Interpretability; Data, AI Ops and Infrastructure; AI Security**. Particularly helpful as a workshop checklist.

Official reference / resource

Microsoft Responsible AI Standard and Azure guidance

PRINCIPLES + IMPLEMENTATION

Best used for: Governance values and practical controls for AI applications, including agent oversight.

Microsoft describes six principles: fairness, reliability and safety, privacy and security, inclusiveness, transparency and accountability. Use platform documentation to see examples of evaluation, lineage, safeguards and operational processes.

Official reference / resource

AWS Responsible AI Lens

ARCHITECTURE GUIDANCE

Best used for: Integrating AI-specific review questions into solution design and delivery.

Lifecycle-oriented best practices; useful to development, cloud architecture and ML engineering teams. Also review the AWS Agentic AI Lens for autonomous AI architecture and operational practices.

Official reference / resource

AWS Cloud Adoption Framework for AI — Governance

OPERATING MODEL GUIDANCE

Best used for: Aligning AI operating models, policies and organizational responsibilities.

Complements the Responsible AI Lens by focusing more directly on enterprise organization and governance processes.

Official reference / resource

IBM AI Risk Atlas and watsonx.governance

RISK TAXONOMY + PRODUCT

Best used for: AI risk identification and examples of model and AI asset oversight workflows.

The Risk Atlas is a research and risk taxonomy resource; **watsonx.governance** is an implementation offering. These are not interchangeable with an enterprise governance standard.

Official reference / resource

03 / Control, security and regulatory references

These resources are best used after the governance model is defined. They translate policy into testable expectations, detailed security practices and jurisdiction-specific obligations.

CSA AI Controls Matrix (AICM) v1.1

CONTROL FRAMEWORK

Best used for: Developing an AI control catalog, assurance tests and third-party due diligence.

Released June 2026; **247 control objectives across 18 domains**. Includes mappings to other frameworks. The related AI-CAIQ questionnaire supports assessment of providers and AI services.

Official reference / resource

OWASP GenAI LLM Top 10 (2026)

APPLICATION SECURITY

Best used for: Assessing common security vulnerabilities in LLM-powered applications.

Covers risks such as prompt injection, sensitive information disclosure and excessive agency. Treat as a specialized security reference, not a complete enterprise governance model.

Official reference / resource

OWASP Top 10 for Agentic Applications (2026)

AGENT SECURITY

Best used for: Security risks involving autonomous behavior, tools, delegated authority and agent workflows.

Relevant when AI agents can use internal data, call tools, execute workflows or initiate external actions; connect to permission boundaries and human approval gates.

Official reference / resource

EU AI Act — official implementation timeline

REGULATORY REFERENCE

Best used for: Checking risk categories, transparency and applicable compliance timelines for EU-connected use cases.

A binding law where applicable, not a voluntary checklist. The published schedule is phased; verify the client's roles, market exposure, use case and the latest legislation before interpreting obligations.

Official reference / resource

Important application note

A framework does not automatically provide compliance, and deploying a vendor's governance product does not discharge accountability. The organization must establish its own controls, operating procedures, evidence and legal applicability analysis.

04 / From data governance to AI governance

Most organizations should extend their existing information governance, cybersecurity and risk structures. The table highlights additions that AI introduces rather than requiring a parallel program.

Existing foundation	AI-specific extension
Data ownership and stewardship	Named AI system owner, decision accountability and defined human oversight
Data catalog and metadata	AI use-case inventory, model/agent registry and third-party AI service register
Data quality and lineage	Model validation, output quality, provenance, dataset/model/prompt dependencies
Security and privacy controls	Agent permissions, model and prompt security, sensitive output controls
Data lifecycle management	AI development, validation, deployment, material changes and retirement
Enterprise risk management	AI risk tiers, system impact assessment and approval thresholds
Monitoring and incident handling	Model and agent evaluation, drift, misuse, failures and AI incidents
Compliance and audit	AI-specific obligations, auditable evidence and independent assurance

Suggested enterprise governance domains

- **01 Strategy and accountability** — Policy, governance committee, executive sponsor, owner roles and decision rights.
- **02 AI inventory and lifecycle** — Registration, risk tiers, third-party intake, changes and retirement.
- **03 Responsible AI and impact** — Fairness, explainability, transparency, affected stakeholders and human review.
- **04 Data and AI security** — Privacy, least privilege, prompt/tool security, supply chain and resilience.
- **05 Validation and operations** — Benchmarking, adversarial testing, monitoring and incident management.
- **06 Compliance and assurance** — Applicable regulations, evidence retention, audit and ongoing reporting.

Recommended control examples

Require AI registration and ownership; risk-tier every consequential use case; validate outputs against documented acceptance criteria; define human review for high-impact decisions; assess external AI suppliers; restrict agent authority; log material changes; monitor incidents and deviations; retain evidence of approvals and re-assessments.

05 / Practical adoption roadmap

A pragmatic research-to-implementation sequence is shown below. The stages are recommendations for client engagements, not phases mandated by any individual standard.

01

Discover and assess

Review existing governance policies and committees, identify deployed AI and shadow AI, establish applicable legal and sectoral requirements.

Outputs: AI inventory; maturity/gap assessment; stakeholder map

02

Define the operating model

Set policy objectives, risk appetite, risk tiers, approval authorities, RACI and the human oversight model.

Outputs: AI governance charter; policy; operating model

03

Design controls and evidence

Select appropriate NIST and ISO outcomes; translate CSA/OWASP into control requirements and audit evidence.

Outputs: Control register; AI impact assessment; release gates

04

Pilot representative use cases

Apply controls to predictive ML, a GenAI application and an AI agent when relevant; refine proportionality.

Outputs: Completed assessments; pilot results; revised procedures

05

Operationalize and improve

Integrate into procurement, data engineering, model deployment, security reviews, monitoring and reporting.

Outputs: Dashboards; training; metrics; governance review cadence

Priority questions for an executive workshop

- What AI do we currently use, including tools bought directly by business teams?
- Which decisions or actions could materially affect people, customers, operations or compliance?
- Who owns each AI system and approves deployment, exceptions and significant changes?
- How do we test, monitor, investigate and stop harmful or incorrect AI behavior?
- How do third-party providers and autonomous agents fit the enterprise risk model?

06 / Selection matrix

Use this matrix to decide which references to prioritize when designing an AI Governance Framework. Ratings represent recommended use, not external certification or formal equivalence.

Reference	Best role in governance design	Priority
NIST AI RMF	AI risk management structure and governance functions	FOUNDATION
ISO/IEC 42001	Formal management system and organizational assurance	FOUNDATION
Databricks DAGF	Practical enterprise governance pillars and checklist	FOUNDATION
CSA AICM	Detailed security controls, evidence and vendor review	FOUNDATION
OECD Principles	Responsible AI values and policy language	SUPPORTING
ISO/IEC 23894 / 42005	Risk methodology and impact assessments	SUPPORTING
Microsoft Responsible AI	Principles, operational examples and Azure alignment	CONTEXTUAL
AWS AI governance / lenses	Cloud and agent architecture and operating practices	CONTEXTUAL
IBM AI Risk Atlas	Risk taxonomy and governance workflows	CONTEXTUAL
OWASP GenAI + agentic	LLM and AI agent security threats and mitigations	SPECIALIST
EU AI Act	Mandatory obligations where legally applicable	LEGAL

What to share first

For executive sponsors: **NIST AI RMF, ISO/IEC 42001, OECD Principles**. For the governance design team: **Databricks DAGF, CSA AICM, ISO/IEC 23894 and 42005**. For engineering and security: **Microsoft, AWS, IBM and OWASP**. For legal and compliance: **EU AI Act and relevant local and sectoral requirements**.

Recommended end-state

A single, enterprise-owned AI Governance Framework: a published policy and operating model, inventory, risk-based lifecycle, control and evidence register, evaluation/monitoring processes, third-party oversight and metrics. Technology implementations may differ across platforms without changing underlying accountability.

07 / Source library and official links

Primary sources curated for research and redistribution as links. The URLs below are active hyperlinks in the PDF; some standards, downloads and vendor resources may require payment or registration. Accessed for this guide in November 2026.

NIST | AI RMF
NIST | AI RMF Playbook
NIST | AI Resource Center / GenAI Profile
ISO | ISO/IEC 42001:2023
ISO | ISO/IEC 23894:2023
ISO | ISO/IEC 42005:2025
OECD | AI Principles
Databricks | AI Governance Framework
Microsoft | Responsible AI / Azure ML
Microsoft | Responsible AI for agents
AWS | Responsible AI Lens
AWS | Agentic AI Lens
AWS | Cloud Adoption Framework for AI - Governance
IBM | AI Risk Atlas
CSA | AI Controls Matrix v1.1
OWASP | GenAI LLM Top 10 (2026)
OWASP | Top 10 for Agentic Applications (2026)
EU | AI Act implementation timeline

About Ensemble Methods

Ensemble Methods combines advisory, training and hands-on implementation across data, machine learning and AI. Learn more at ensemblemethods.com.

Editorial note: This guide is independent research and synthesis based on public materials from the referenced organizations. It is not issued, accredited, endorsed or certified by them. Descriptions and priorities are intended for research and planning, not legal advice.